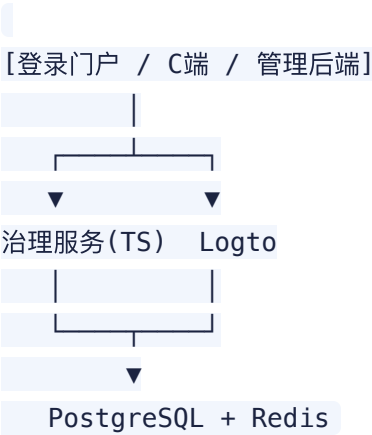


lecoo 统一登录 · 架构与资源方案（方案 O） V1.0

1. 逻辑架构



详情：`架构图/01-总体架构图.html`、`02-部署架构图.html`。

2. 部署

- `apps/web`：Next.js BFF + UI
- Logto：独立容器（见仓库 `docker-compose.logto.yml`）
- PostgreSQL：gov + audit schema
- Redis：限流 / 踢人指令辅助

3. 资源估算（MVP）

资源	规格建议	备注
Web/API	2 × 小规格容器	可与现有 monorepo 同部署
Logto	1 × 中规格	生产建议 2 副本
PostgreSQL	托管 2 vCPU / 4–8GB	治理 + 审计分区
Redis	托管 1GB	非会话权威源

4. 安全基线

- 仅 Auth Code + PKCE；禁 Implicit / ROPC
- redirect_uri 精确匹配；state/nonce 强制
- RT 轮换 + 重放检测；AT 短 TTL
- secret 一次展示 + 哈希存储
- 高危操作二次确认 + 全量审计

5. 观测

- 登录漏斗：发码 / 验码 / bootstrap / 选租户成功率
- 延迟：token exchange P95
- 安全：锁定、踢人、secret rotate 计数

O–V1.5 安全认证补充

- MFA 与生物识别策略由管理端配置，执行面结合 Logto MFA + WebAuthn/平台生物 API。
- 手机端支持生物快速解锁与 Step-up；生物特征模板不出设备，仅持久化 credential 引用与审计事件。